

PLAN DE MISE EN CONFORMITÉ

Système d'Identification Biométrique Multimodal

BIOID-MULTIMODAL v1.0.0

Projet Académique - Roadmap de Conformité

Actions Prioritaires | Planning Synthétique

Objectif : Score 63.3% → 80%

Date d'élaboration : 4 janvier 2026

Score actuel : 63.3% (Partiellement conforme)

Score cible : 80% (Conforme pour production)

Contexte : Projet académique - Plan théorique

Périmètre	15 actions prioritaires
Horizon temporel	3-4 mois (si production réelle)
Phases	3 phases (Critique, Haute, Moyenne)

Document Académique

Table des matières

Résumé Exécutif	3
1 État des Lieux et Priorisation	4
1.1 Scores Actuels par Domaine	4
1.2 Matrice de Priorisation	4
1.2.1 Légende des Priorités	4
1.2.2 Liste des 15 Actions Prioritaires	5
2 Actions Prioritaires par Phase	6
2.1 Phase 1 : Actions Critiques (P0)	6
2.1.1 A1 : Déclaration CNDP	6
2.1.2 A2 : Implémentation HTTPS/TLS	7
2.1.3 A3 : Liveness Detection	7
2.2 Phase 2 : Actions Haute Priorité (P1)	7
2.2.1 A4 : Alternative Non-Biométrique	7
2.2.2 A5 : Tests de Biais Algorithmiques	8
2.2.3 A6-A8 : Actions Complémentaires P1	8
2.3 Phase 3 : Actions Moyenne Priorité (P2)	8
2.3.1 Actions P2 - Vue d'Ensemble	9
3 Planning et Ressources	10
3.1 Planning Global	10
3.1.1 Timeline Synthétique	10
3.1.2 Jalons (Milestones)	10
3.2 Ressources Estimées	10
3.2.1 Pour un Projet Académique	10
3.2.2 Pour une Production Réelle	11
3.3 Risques et Mitigation	11
4 Validation et Décision de Production	12
4.1 Checklist de Mise en Production	12
4.1.1 Critères Bloquants (GO/NO-GO)	12
4.2 Distinction Académique vs Production	13
4.2.1 Pour un Projet Académique	13
4.2.2 Pour une Production Réelle	13
4.3 Surveillance Post-Production	13
5 Conclusion et Perspectives	14
5.1 Synthèse du Plan	14
5.1.1 Actions Bloquantes (P0)	14

5.1.2	Actions Recommandées (P1-P2)	14
5.2	Applicabilité Académique	14
5.2.1	Ce qui est Démontré	14
5.2.2	Limitations Reconnues	15
5.3	Recommandations Finales	15
5.3.1	Pour Compléter le Projet Académique	15
5.3.2	Pour une Mise en Production	15
5.4	Conclusion	16
A	Contacts et Ressources	17
A.1	Contacts Institutionnels	17
A.1.1	CNDP Maroc	17
A.1.2	CNIL France (Référence RGPD)	17
A.2	Ressources Techniques	17
A.2.1	Sécurité et Chiffrement	17
A.2.2	Standards et Normes	17
A.2.3	Outils Recommandés	18
A.3	Textes Légaux	18
A.3.1	Législation Marocaine	18
A.3.2	Législation Internationale	18

Résumé Exécutif

Contexte

Le système BIOID-MULTIMODAL a obtenu un score de conformité de **63.3%**, le classant comme **partiellement conforme**. Ce plan détaille les actions nécessaires pour atteindre le score minimal de **80%** requis pour une mise en production sécurisée et conforme.

Contexte académique : Ce document présente un plan théorique de mise en conformité à des fins éducatives, démontrant la compréhension des exigences et des actions requises.

Objectifs

1. Identifier les **3 problèmes critiques** bloquant la production
2. Définir les **15 actions prioritaires** (P0-P1-P2)
3. Proposer un planning de mise en conformité
4. Comprendre les exigences légales et techniques

Vue d'Ensemble

Phase	Durée	Actions	Impact Score	
Phase 1 - Critique (P0)	1 semaine	3 actions	+35%	
Phase 2 - Haute (P1)	1 mois	5 actions	+32%	
Phase 3 - Moyenne (P2)	2 mois	7 actions	+21%	
TOTAL	3-4 mois	15 actions	80%	

TABLE 1 – Phases du plan de conformité

Actions Critiques (P0)

1. **Déclaration CNDP** - Obligatoire avant production
2. **HTTPS/TLS** - Chiffrement des communications
3. **Liveness detection** - Protection anti-spoofing

Note : Pour un projet académique, ces actions sont documentées et comprises sans nécessairement être implémentées en production.

Chapitre 1

État des Lieux et Priorisation

1.1 Scores Actuels par Domaine

Domaine	Score Actuel	Cible	Écart
Conformité Légale	50%	90%	+40%
Sécurité Technique	60%	85%	+25%
Protection Vie Privée	80%	90%	+10%
Éthique et Biais	30%	70%	+40%
GLOBAL	63.3%	80%	+16.7%

TABLE 1.1 – Écarts à combler par domaine

1.2 Matrice de Priorisation

1.2.1 Légende des Priorités

Niveau	Description	Délai
P0 - Critique	Bloquant production, risque légal/sécuritaire majeur	Immédiat
P1 - Haute	Impact significatif conformité, risque modéré	Court terme
P2 - Moyenne	Amélioration recommandée, bonnes pratiques	Moyen terme

TABLE 1.2 – Niveaux de priorité

1.2.2 Liste des 15 Actions Prioritaires

ID	Action	Priorité	Impact
Phase 1 - Critique (P0)			
A1	Déclaration CNDP	P0	+15%
A2	Implémentation HTTPS/TLS	P0	+10%
A3	Liveness detection (facial)	P0	+10%
Phase 2 - Haute Priorité (P1)			
A4	Alternative non-biométrique	P1	+8%
A5	Tests de biais algorithmiques	P1	+12%
A6	MFA pour administrateurs	P1	+5%
A7	Registre des traitements	P1	+3%
A8	Sécuriser secret JWT	P1	+4%
Phase 3 - Moyenne Priorité (P2)			
A9	Rate limiting API	P2	+3%
A10	Salt cryptographique unique	P2	+2%
A11	Sauvegardes automatiques	P2	+4%
A12	Procédure notification violation	P2	+2%
A13	Formation personnel	P2	+3%
A14	Politique mots de passe renforcée	P2	+2%
A15	Audit externe	P2	+5%

TABLE 1.3 – Matrice complète des actions

Chapitre 2

Actions Prioritaires par Phase

2.1 Phase 1 : Actions Critiques (P0)

2.1.1 A1 : Déclaration CNDP

Objectif : Déclarer le traitement auprès de la Commission Nationale de contrôle de la protection des Données (CNDP) conformément à la Loi 09-08 Art. 3.

Base légale :

- Loi 09-08 Art. 3 : Déclaration obligatoire AVANT mise en production
- Données biométriques = données sensibles → autorisation préalable possible

Sanction en cas de non-respect :

- Prison : 3 mois à 1 an
- Amende : 20,000 à 200,000 MAD

Documents à fournir :

1. Formulaire de déclaration CNDP rempli
2. Description finalités du traitement
3. Liste catégories de données biométriques
4. Mesures de sécurité (AES-256, RBAC, etc.)
5. Politique de rétention (5 ans)
6. Formulaire de consentement

Contact CNDP :

- Site : <https://www.cndp.ma>
- Email : contact@cndp.ma
- Téléphone : +212 537 57 73 44
- Adresse : 6, Rue Bani Yèder, Hay Ryad, Rabat

Délai de réponse : 2 mois maximum

Impact : +15% score conformité

2.1.2 A2 : Implémentation HTTPS/TLS

Objectif : Activer le chiffrement en transit via HTTPS/TLS pour protéger les communications.

Problème actuel :

- Aucune configuration SSL/TLS
- Données biométriques exposées en clair lors du transit
- Tokens JWT interceptables (Man-in-the-Middle)

Solution :

1. Obtenir certificat SSL (Let's Encrypt gratuit ou commercial)
2. Configurer serveur web (Nginx/Gunicorn)
3. Activer TLS 1.2 minimum
4. Rediriger HTTP → HTTPS

Validation :

- Grade SSL Labs : A ou A+
- Tous les endpoints accessibles via HTTPS
- Certificat valide et non expiré

Impact : +10% score sécurité

2.1.3 A3 : Liveness Detection

Objectif : Implémenter détection de vivacité pour prévenir attaques par spoofing (photos, vidéos).

Problème actuel :

- Système accepte une simple photo imprimée
- Vulnérable aux attaques par replay vidéo
- Pas de vérification de présence réelle

Solutions possibles :

1. **Niveau 1 :** Détection de clignement des yeux
2. **Niveau 2 :** Challenge aléatoire (tourner la tête)
3. **Niveau 3 :** Deep learning PAD (ISO 30107)

Recommandation académique : Niveau 1 (détection clignement) comme preuve de concept.

Impact : +10% score sécurité

2.2 Phase 2 : Actions Haute Priorité (P1)

2.2.1 A4 : Alternative Non-Biométrique

Objectif : Proposer méthode manuelle d'identification pour personnes refusant la biométrie.

Justification éthique :

- Consentement doit être libre (Loi 09-08 Art. 8)
- Pas de contrainte sur populations vulnérables
- Respect droits humains (Principes de Johannesburg)

Solution proposée :

- Carte d'identité plastifiée avec photo
- Code-barres/QR code unique
- Vérification visuelle par agent formé
- Procédure documentée

Impact : +8% score conformité

2.2.2 A5 : Tests de Biais Algorithmiques

Objectif : Mesurer performances par groupe démographique (genre, âge, origine) pour détecter biais.

Risque : Discrimination algorithmique non détectée.

Dataset requis :

- Minimum 200 personnes
- 50% hommes / 50% femmes
- Répartition âge : 18-30 (33%), 30-50 (33%), 50+ (33%)
- Diversité ethnique représentative

Métriques à calculer :

- FAR/FRR par groupe démographique
- Écart maximum acceptable : < 5%
- Fairness metrics (demographic parity, equal opportunity)

Impact : +12% score éthique

2.2.3 A6-A8 : Actions Complémentaires P1

ID	Action	Impact
A6	MFA pour administrateurs (TOTP/Google Authenticator)	+5%
A7	Registre des traitements (RGPD Art. 30)	+3%
A8	Sécuriser secret JWT (supprimer valeur par défaut)	+4%

TABLE 2.1 – Actions complémentaires P1

2.3 Phase 3 : Actions Moyenne Priorité (P2)

2.3.1 Actions P2 - Vue d'Ensemble

ID	Action	Description
A9	Rate limiting	Protection brute-force (Flask-Limiter)
A10	Salt crypto unique	Générer salt aléatoire par installation
A11	Sauvegardes auto	Backup PostgreSQL quotidien chiffré
A12	Procédure violation	Plan réponse incidents (< 72h CNDP)
A13	Formation personnel	9h formation (RGPD, sécurité, éthique)
A14	Politique mots de passe	Min 12 caractères, complexité renforcée
A15	Audit externe	Penetration testing + revue conformité

TABLE 2.2 – Actions Phase 3

Impact cumulé Phase 3 : +21% score global

Chapitre 3

Planning et Ressources

3.1 Planning Global

3.1.1 Timeline Synthétique

Phase	Durée	Jalons Clés
Phase 1 - P0	Semaine 1	HTTPS actif, Liveness implémenté, Dossier CNDP envoyé
Attente CNDP	2 mois	Obtention autorisation/récépissé CNDP
Phase 2 - P1	Mois 1	Alternative créée, Tests biais réalisés, MFA actif
Phase 3 - P2	Mois 2-3	Toutes actions P2, Audit externe, Score 80%
Production	Mois 4	Mise en ligne autorisée si conforme

TABLE 3.1 – Planning par phase

3.1.2 Jalons (Milestones)

1. **M1 - Phase 1 terminée** : HTTPS + Liveness + Dossier CNDP (Semaine 1)
2. **M2 - Autorisation CNDP** : Récépissé obtenu (Mois 2)
3. **M3 - Tests biais validés** : Écarts < 5% (Mois 2)
4. **M4 - Score 80%** : Toutes actions P0-P2 terminées (Mois 3)
5. **M5 - Audit externe** : Rapport validé (Mois 3)
6. **M6 - Production** : Go-live autorisé (Mois 4)

3.2 Ressources Estimées

3.2.1 Pour un Projet Académique

Objectifs :

- Démontrer compréhension des exigences
- Documenter les actions requises
- Simuler le processus de conformité

Livrables académiques :

1. Documentation des actions P0-P1-P2
2. Exemple de formulaire CNDP
3. Exemple de formulaire de consentement
4. Checklist de validation
5. Analyse critique des limitations

3.2.2 Pour une Production Réelle

Ressources humaines :

- Chef de projet : 0.5 ETP (3-4 mois)
- Développeur : 1 ETP (3-4 mois)
- Juriste : 0.5 ETP (1 mois)
- Data scientist : 0.5 ETP (1 mois)
- DevOps : 0.5 ETP (ponctuel)

Budget estimé :

Poste	Fourchette (EUR)
Développement et implémentation	3,000 - 8,000
Dataset de test et validation	2,000 - 5,000
Audit externe et certification	3,000 - 10,000
Consulting juridique (CNDP)	1,000 - 2,000
Formation et documentation	1,000 - 3,000
TOTAL	10,000 - 28,000

TABLE 3.2 – Budget global (production réelle)

3.3 Risques et Mitigation

Risque	Prob.	Mitigation
Délai CNDP > 2 mois	Moyen	Commencer immédiatement, suivre régulièrement
Dataset test insuffisant	Faible	Partenariats, données synthétiques
Biais non-corrigeables	Faible	Ajustement seuils, multi-modalité
Budget dépassé	Moyen	Prioriser P0-P1, reporter P2

TABLE 3.3 – Risques principaux

Chapitre 4

Validation et Décision de Production

4.1 Checklist de Mise en Production

4.1.1 Critères Bloquants (GO/NO-GO)

ID	Critère	Statut
Juridique et Conformité		
C1	Autorisation CNDP obtenue	
C2	Formulaires de consentement validés	
C3	Alternative non-biométrique opérationnelle	
C4	Registre des traitements créé	
Sécurité Technique		
S1	HTTPS/TLS actif (grade A)	
S2	Liveness detection fonctionnelle	
S3	MFA activé pour administrateurs	
S4	Secret JWT sécurisé (pas de défaut)	
S5	Rate limiting configuré	
Éthique et Biais		
E1	Tests de biais réalisés (200+ personnes)	
E2	Écarts FAR/FRR < 5% tous groupes	
E3	Rapport de biais documenté	
Qualité		
Q1	Tests d'acceptation passés	
Q2	Audit externe validé	
Opérationnel		
O1	Personnel formé (100%)	
O2	Documentation complète	
O3	Plan réponse incidents créé	
Score		
SC1	Score global 80%	
SC2	Aucun problème P0 en cours	

TABLE 4.1 – Checklist de validation finale

Décision : Production autorisée **SI ET SEULEMENT SI** tous les critères sont cochés.

4.2 Distinction Académique vs Production

4.2.1 Pour un Projet Académique

Objectifs validés :

- Compréhension des enjeux légaux (Loi 09-08, RGPD)
- Identification des actions prioritaires
- Proposition de solutions techniques
- Analyse critique des limitations

Livrables académiques suffisants :

1. Ce plan de mise en conformité documenté
2. Rapport d'audit avec score 63.3%
3. Identification claire des 15 actions
4. Compréhension du processus CNDP
5. Documentation des exigences techniques

4.2.2 Pour une Production Réelle

Obligations supplémentaires :

1. Obtenir **réellement** l'autorisation CNDP
2. Implémenter **toutes** les actions P0-P1
3. Réaliser tests de biais avec **vraies données**
4. Passer audit externe par organisme certifié
5. Former le personnel
6. Mettre en place infrastructure de production
7. Assurance responsabilité civile
8. Support juridique permanent

4.3 Surveillance Post-Production

Si mise en production réelle :

- Monitoring 24/7 (uptime, performance)
- Revue mensuelle logs d'audit
- Tests de biais trimestriels
- Audit externe annuel
- Mise à jour documentation continue
- Révision CNDP si changements majeurs

Chapitre 5

Conclusion et Perspectives

5.1 Synthèse du Plan

Ce plan de mise en conformité identifie **15 actions prioritaires** réparties en 3 phases pour faire passer le score de conformité de **63.3% à 80%+**.

5.1.1 Actions Bloquantes (P0)

1. **Déclaration CNDP** - Obligation légale incontournable
2. **HTTPS/TLS** - Sécurité des communications
3. **Liveness detection** - Protection anti-spoofing

5.1.2 Actions Recommandées (P1-P2)

- Alternative non-biométrique (éthique)
- Tests de biais (équité algorithmique)
- Renforcements sécurité (MFA, rate limiting, etc.)
- Formation et gouvernance

5.2 Applicabilité Académique

5.2.1 Ce qui est Démontré

Compétences académiques validées :

- Compréhension du cadre légal marocain (Loi 09-08)
- Connaissance des exigences internationales (RGPD, ISO)
- Identification des vulnérabilités techniques
- Priorisation des actions selon impact
- Capacité à planifier un projet de conformité

5.2.2 Limitations Reconnues

Pour un projet académique :

- Déclaration CNDP simulée (non effectuée réellement)
- Tests de biais sur données synthétiques ou limitées
- HTTPS non implémenté (environnement local)
- Pas d'audit externe professionnel

Ces limitations sont acceptables dans un contexte éducatif.

5.3 Recommandations Finales

5.3.1 Pour Compléter le Projet Académique

1. Documentation :

- Créer exemple de formulaire CNDP rempli
- Rédiger formulaire de consentement papier
- Documenter procédure alternative manuelle

2. Démonstration technique :

- Simuler détection de clignement (liveness niveau 1)
- Implémenter rate limiting basique
- Créer script de backup simulé

3. Analyse critique :

- Identifier limitations éthiques du système
- Proposer améliorations futures
- Comparer avec systèmes existants

5.3.2 Pour une Mise en Production

Horizon temporel : 3-4 mois

Budget : 10,000 - 28,000 EUR

Pré-requis absolus :

- Autorisation CNDP obtenue
- Score 80%
- Tous critères P0-P1 validés
- Audit externe passé
- Personnel formé

5.4 Conclusion

PLAN DE MISE EN CONFORMITÉ

Score Actuel : **63.3%**
Score Cible : **80%**

Contexte Académique :

PLAN VALIDÉ

Démontre maîtrise des enjeux de conformité biométrique

Production Réelle :

15 ACTIONS REQUISES

3 phases sur 3-4 mois | Budget 10-28k EUR

Points clés :

- Plan structuré en 3 phases (P0-P1-P2)
- 15 actions prioritaires identifiées
- Déclaration CNDP obligatoire avant production
- Tests de biais essentiels pour équité
- Score 80% requis pour autorisation production

Annexe A

Contacts et Ressources

A.1 Contacts Institutionnels

A.1.1 CNDP Maroc

Commission Nationale de contrôle de la protection des Données à caractère Personnel

- **Site web** : <https://www.cndp.ma>
- **Email** : contact@cndp.ma
- **Téléphone** : +212 537 57 73 44
- **Fax** : +212 537 71 78 26
- **Adresse** : 6, Rue Bani Yèder, Hay Ryad, BP 6354, Rabat
- **Horaires** : Lundi-Vendredi, 9h-17h

A.1.2 CNIL France (Référence RGPD)

- **Site web** : <https://www.cnil.fr>
- **Téléphone** : +33 1 53 73 22 22

A.2 Ressources Techniques

A.2.1 Sécurité et Chiffrement

- Let's Encrypt (SSL gratuit) : <https://letsencrypt.org>
- OWASP Top 10 : <https://owasp.org/www-project-top-ten/>
- SSL Labs Test : <https://www.ssllabs.com/ssltest/>

A.2.2 Standards et Normes

- ISO/IEC 27001 (Sécurité) : <https://www.iso.org/isoiec-27001>
- ISO/IEC 24745 (Biométrie) : <https://www.iso.org>
- ISO/IEC 30107 (PAD) : <https://www.iso.org>
- NIST Biometrics : <https://www.nist.gov/itl/iad/biometrics>

A.2.3 Outils Recommandés

- **Audit sécurité** : OWASP ZAP, Bandit, Safety
- **Biais algorithmiques** : AI Fairness 360 (IBM), Fairlearn (Microsoft)
- **Rate limiting** : Flask-Limiter
- **MFA** : pyotp (Python TOTP)

A.3 Textes Légaux

A.3.1 Législation Marocaine

- **Loi 09-08** : Protection données personnelles (2009)
 - Bulletin Officiel : http://www.sgg.gov.ma/BO/fr/2009/bo_5714_fr.pdf
- **Décret 2-09-165** : Application de la loi 09-08
- **Loi 05-20** : Cybersécurité (2020)

A.3.2 Législation Internationale

- **RGPD** : Règlement UE 2016/679
 - EUR-Lex : <https://eur-lex.europa.eu/eli/reg/2016/679>
- **Principes de Johannesburg** : Biométrie et droits humains (2018)